

DEGREE PROJECT FOR MASTER OF COMPUTER SCIENCE WITH
SPECIALIZATION IN CYBERSECURITY DEPARTMENT OF ENGINEERING
SCIENCE UNIVERSITY WEST

Automated Compliance Mapping for IoT and AI Security Standards: An NLP-Based Approach for ETSI EN 303 645 and EN 304 223

A case study

Ashish Gurung
Bivishan Dhungana



A THESIS SUBMITTED TO THE DEPARTMENT OF ENGINEERING SCIENCE
IN PARTIAL FULFILMENT OF THE REQUIREMENTS FOR THE DEGREE OF
MASTER OF COMPUTER SCIENCE WITH SPECIALIZATION IN CYBERSECURITY
AT UNIVERSITY WEST
May 10, 2026

Author(s):	Ashish Gurung Bivishan Dhunghana
Supervisor:	Fatiha Djebbar
Examiner:	Eleftherios Vlahakis
Program:	Master Programme in Cybersecurity
Main field of study:	Computer Science
Credits:	60 Higher Education credits
Keywords:	Word1, Word2, Word3, Word4, Word5
Template:	University West, IV-Master 2.10
Publisher:	University West, Department of Engineering Science S-461 86 Trollhättan, SWEDEN Phone: + 46 520 22 30 00 Fax: + 46 520 22 32 99 Web: www.hv.se

Summary

The student must write a summary with a short background and the major results and conclusions. A summary presents all the major elements of the thesis in a highly condensed form and should therefore not exceed half a page. A common error is to fail in presenting the result. The main purpose of the thesis is to explain your discovery and how you reach that, not all steps you did present as a diary.

Preface

The preface should be short and only containing related work information without the technical content. For example, give the facts about the report's creation which does not affect the technical content. It is appropriate [1]to acknowledge any substantial contributions from other individuals or organizations. It is not necessary to include a Preface to the report, but often very useful. If not used, please remove the entire page.

Affirmation

This master degree report, A Short descriptive title of the work, was written as part of the master degree work needed to obtain a Master of Science with specialization in Cybersecurity degree at University West. All material in this report, that is not my own, is clearly identified and used in an appropriate and correct way. The main part of the work included in this degree project has not previously been published or used for obtaining another degree [2].

Ashish Gurung

Date

Bivishan Dhunghana

Date

Contents

1	Introduction	1
1.1	Motivation	2
1.2	Aim	3
1.3	Research questions	3
1.4	Contributions	3
2	Background and Related Work	5
2.1	Background	5
2.1.1	IoT Security and Standards	5
2.1.2	AI System Security and Standards	6
2.1.3	Regulatory Compliance Mapping	7
2.1.4	Natural Language Processing (NLP) and LLM Techniques	7
2.2	Related work	9
2.2.1	Automated Compliance Mapping in Cybersecurity	9
2.2.2	NLP and Semantic Techniques for Requirement Mapping	9
2.2.3	LLM-Based Approaches for Compliance Analysis	10
3	Research Methodology	12
3.1	Research Design	12
3.2	Data Gathering Methods	13
3.2.1	Text Pre-processing	14
3.3	Automated Mapping Approaches	15
3.4	Implementation of Mapping Algorithm	15
3.4.1	Classification of Mapping Relationships	16
3.4.2	Experimental evaluation of mapping performance	16
3.5	Similarity Computation	18
3.6	Model comparison	19
4	“Prototype”	21
5	Results and discussion	22
	Conclusion	23
5.0.1	Future Work and Research	23
5.0.2	Critical Discussion	23

5.0.3	Generalization of the result	23
	Bibliography	24

1 | Introduction

The evolution in industrial automation is increasingly shifting from traditional rule based automation systems towards the adoption of Agentic Artificial Intelligence (AI)[3]. The rapid growth of Internet of Things (IOT) devices and Artificial Intelligence (AI) systems has transformed modern digital automation ecosystem's, enabling systems to learn, adopt and make decisions autonomously with minimal human intervention[4][5]. However, the expansion of automation in IoT devices and AI systems creates new attack vectors and surfaces for cyber threats, exposing user data, system vulnerabilities in device authentication, data integrity, privacy, and safety to potential threats [6]. As a result, for regulatory and standardization many organizations have introduced comprehensive security frameworks to mitigate these risks[7]. To ensure secure deployment of connected technologies, organizations must prioritize secure development and adhere to established security standards. The two key standards that are of interest are ETSI EN 303 645 and ETSI EN 304 223[8][9]. These standards are developed for professional IoT devices and AI system security, respectively. ETSI EN 304 223 is introduced for security considerations related to AI-enabled systems, including risk management, transparency, data governance, and model robustness[9]. Meanwhile, ETSI EN 303 645 provides baseline requirements for consumer industrial IoT devices, focusing on protection of personal data, secure communication, vulnerability disclosure policies, and software updates[8]. Together, The main aim of these standards is to protect the confidentiality, integrity, and availability of the device to enhance trust, reliability, and resilience in connected environments.

Despite their importance, implementing automation to comply with these standards presents complex, time-consuming process accompanied by multiple challenges[6]. Organizations have to manually interpret lengthy technical documents while developing AI enabled systems making it more challenging to identify relevant security requirements simultaneously[10]. ETSI EN 303 645 (consumer IoT security) and ETSI EN 304 223 (AI system security) contain dozens of requirements expressed in natural language, with different levels of specification and overlapping problem which makes difficult to map them to their system architecture, policies, and controls[11]. While, both outline security goals, they lack clear instructions to implement guidance which creates various uncertainties during verification processes[12][5]. This process is often not consistent, error-prone and takes a lot of resources. These effects are particularly complex when dealing with overlapping requirements across IoT and AI domains[13].

Moreover, As regulatory requirements increases such as differences in volume and diversity of structure, terminology and requirements, multiplies (EU Cyber Resilience Act, AI Act, sector-specific standards), the burden of compliance documentation within the

systems grows exponentially[14]. This growth creates additional challenges for developers, system analysts, and compliance professionals to understand semantic similarities across standards and ensures that implemented controls satisfy the all applicable requirements. These challenges are further compounded by the rapid growth of IoT devices and AI technologies, which often introduces new rules and requirements which makes the scenario even worse. Currently, There aren't many systematic automated tools that are capable of intelligently map and align the requirements between IoT and AI security standards. This gap creates less efficiency in compliance processes, results increment in implementation costs, and develops the risk of inconsistent or incomplete security coverage. Traditional keyword-based approaches for document comparison are inadequate due to the regulatory language often contains context-dependent terminology, implicit meanings, and complex relationships among clauses[15]. Therefore, there is a clear need for advanced methods and techniques that can understand the semantic meaning within regulatory texts[16].

Today, recent advances in Natural Language Processing (NLP), a subfield of Artificial Intelligence, offer promising solutions to automate and enhance compliance analysis[17]. NLP techniques such as text classification, semantic similarity analysis, named entity recognition, and transformer based language models enable machines to interpret regulatory documents and extract meaningful relationships between requirements[18][16]. Using these technologies, it is possible to create smart systems that can automatically map security requirements across many standards, thereby reducing manual effort and improving accuracy.

1.1 Motivation

Using NLP and LLMs to automate compliance mapping between ETSI EN 303 645 and EN 304 223 solves a real challenges point for organizations which shows the increasingly complex landscape of AI and IoT security standards. By systematically comparing automated mapping results with expert-generated mappings, the project helps identify the current limitations of AI-assisted compliance tooling and clarifies where human expertise remains indispensable. Recent advances in Natural Language Processing (NLP), particularly transformer-based models and large language models (LLMs), offer potential for automating or semi automating compliance mapping tasks. However, the applicability of these techniques to security standards, which require precision, completeness, and interpretability, remains under explored. This thesis investigates whether and how AI assisted methods can accurately map security controls between ETSI EN 303 645 and EN 304 223, evaluating the feasibility, accuracy, and limitations of automated approaches for standards compliance. The project is timely and relevant, addressing a real-world industrial problem while contributing scientifically valuable knowledge on the use of NLP and AI for security standards analysis. The outcome has the potential to support future research, improve industrial compliance practices, and inform the design of trustworthy AI assisted compliance tools.

1.2 Aim

This thesis project proposes an NLP-based approach for automated compliance mapping framework that identifies semantic relationships between requirements in ETSI EN 303 645 and ETSI EN 304 223. The objective is to train the different models that can analyze textual clauses from both standards and determine equivalence, similarity, or complementary relationships between the two standards. The research investigates whether and how AI-assisted methods can accurately map security controls between IoT and AI security standards. Furthermore, this project evaluates the feasibility, accuracy, and limitations of automated approaches for standards compliance. The proposed project could support organizations in performing an automated gap analysis mechanism understanding overlapping obligations and identifying conflicts compare to manual expert mapping. This approach can help to avoid redundant implementations and ensures which methods achieve the best balance of accuracy, completeness, interpretability, and consistency compliance across IoT and AI security frameworks.

1.3 Research questions

The following research questions are divided into three major themes where, RQ1 is focused to identify the semantic relationship between security requirements and also to find the fundamentals limitations and challenges while the RQ2, is aims to evaluate the different automated approaches such as model analysis, model evaluation, and comparison to perform the automated compliance mapping tasks. Finally, RQ3 compares automated mapping results with manual expert mapping in terms of performance and practical applicability.

1. To what extent can NLP and AI techniques automatically identify semantic relationships (equivalence, overlap, sub Sumption, complementarity) between security requirements in ETSI EN 303 645 and EN 304 223? What are the fundamental challenges and limitations?
2. How do different automated approaches (Rule-based NLP, Semantic (BERT-based, sentence embedding), LLM (GPT, Claude)) perform for compliance mapping tasks? Which methods achieve the best balance of accuracy, completeness, and interpretability?
3. How does automated mapping compare to manual expert mapping in terms of: Accuracy, coverage, efficiency and interpretability.

1.4 Contributions

The major contribution of this thesis project is elaborated below:

- Comprehensive Review: This review provides an in-depth analysis of NLP approaches on automated compliance on ETSI EN 303 645 and EN 304 223 standards .

- A simple framework that identifies semantic relationships (equivalence, overlap, subsumption, complementarity) between requirements in ETSI EN 303 645 and ETSI EN 304 223. It supports both IoT and AI security standards, bridging a gap in current compliance automation tools.
- Comparative Study: This work presents a comparative analysis of practical approach for integrating multiple AI/NLP techniques for standards compliance with evaluating their effectiveness, scalability, and applicability.
- The project highlights the systematic evaluation of automated mapping results against manual expert-generated mappings providing empirical evidence of feasibility and limitations.
- The project helps to identifies the overlapping and complementary requirements between IoT and AI standards and provides new knowledge on gaps and challenges in mapping AI and IoT security controls.
- The project helps to contribute the research community by supporting further research in automated compliance, cybersecurity, and AI governance.

2 | Background and Related Work

The background portion explains the theoretical parts of our proposed master degree projects. This section is very crucial and is composed of facts and theories that our report is relies on with proper literature reference. It covers the areas like IOT and AI standards and their security issues while complying automatically.

This section also explore currently available methods, techniques and models from manual and automated compliance mapping [19, 20], in order to understand the fundamentals of how semantic similarity can be processed. Following the existing papers on this domain would provides the relevant technique, their limitation and research gaps in automating compliance between two standards. By evaluating related research paper, their methods and discussion, It is very effective to demonstrate our research based on the past studies and would support in developing our effective automated compliance mapping.

2.1 Background

2.1.1 IoT Security and Standards

Iot Security Challanges

Iot devices are often interlinked or connected world wide through internet or often wireless and some devices are manufactured with built in computing power[21]. This is why they pose a lot of security problems as they may have limited and certain level of security control. In general common issues with IOT may include poor authentication mechanism, unprotected software updates, unencrypted communications, unnecessary exposed interfaces, Insufficient protection for individual information and a lack of resilience whenever system shutdown or in case of disconnection with network access and many more[22]. These weakness makes the devices vulnerable. These flaws are significant because a lot of devices used by consumers are utilized in homes and everyday situations. In such a scenario, a tiny breaches of security can compromise trust issue, safety, and privacy concern[23]

ETSI EN 303 645

ETSI EN 303 645 is a baseline cybersecurity standard for consumer Internet of Things (IOT) devices[8]. The mentioned standard is responsible for enforcing the high level requirements into the appropriate security practices for the consumer's interconnected electronic devices like smart cameras, smart headphone, wearable, home equipments etc. Furthermore, it

has a major role in focusing some serious problem and limitation of IOT devices, for like default password, not secured communication, poor handling of vulnerability, secured and protected storage, resilience etc[22]. The standard is also deals with security-by-design and also supports in enhancing the better protection of individual data in IOT devices. ETSI EN 303 645 has support security by design as an general principle but is reflected in several provisions such as provision 5.3 (Keep software updated), 5.5 (communicate securely), 5.6 (Minimize exposed attack surfaces), and 5.7 (Ensure software integrity)[8]. Additionally, Individual data security clause are mentioned in provision 5.8 (ensuring personal data is secured), 5.11 (Easy process for user to delete their data) and provision 6 (Protection of data for consumer IOT).[8]

2.1.2 AI System Security and Standards

Security Challenges in AI systems

AI systems faces a lot of different security challenges than that of traditional software[24]. Nowadays, AI are heavily depend on training of data, behavior of model, provided prompts and interaction with the worldwide supply chain[24]. As a result, AI security requirements under ETSI 304223 highlights data poisoning risk, model manipulation and indirect prompt injection [9]. As a result, AI security must mention model security, life-cycle governance and data security along with a software security[25].

ETSI EN 304 223

ETSI EN 304 223 is a baseline cybersecurity standard for AI models and AI systems[9]. Along with the time, traditional software security protocols were not able to covered the new aged AI security risks, such as data poisoning, adversarial attack, data leakage, misuse of model and other prompts related vulnerabilities[25]. So, to address those weakness, ETSI EN 304223 standard was developed.

ETSI EN 304 223 classifies the AI security requirements based on system life cycle, making the standard appropriate and ideal for systematic control mapping. As we can see in ETSI EN 304223 Clause 5, the standard classifies its provisions into five different phases, which are secure design in claus 5.1, secure development in 5.2, secure deployment in 5.3, secure maintenance (5.4), and secure end of life (5.5). The standard also defines major AI-security control areas, which include AI-specific threat and risk management in provision 5.1.3, documentation and audit-ability of models in Claus 5.1.2-3, datasets and prompts in provision 5.2.4, supply-chain security (5.2.3), security testing and evaluation (5.2.5), logging and behavioral monitoring (5.4.2), and secure data/model disposal (5.5.1)[9].

For performing compliance mapping automatically, mentioned life-cycle and artifact-based standard is most beneficial because it can distinguish AI security into unique requirement categories[26] which can be compared more easily with our corresponding provisions in ETSI EN 303 645. ETSI EN 304223 is appropriate for our compliance mapping task because its lifecycle based structure segregate AI security into design, development, maintenance. So this structure fully support the comparative analysis with the ETSI EN 303 645's provision-based organization.

2.1.3 Regulatory Compliance Mapping

Manual Mapping

Manual compliance mapping is comparatively more challenging because the different standards follow different structure and using varying words for achieving the similar kind of security objectives. Research on standards reveals that overlapping of control, inconsistencies among the standards, requirements fragmentation and risk of redundant work are some major challenges organizations are facing more often[19]. The study also mentioned, different standard mapping often need interpretation based on the purpose and security objective along with involving wording of control[19]. Hence, the process makes manual mapping slower and more dependent on expert knowledge and supervision[20][27].

Similar kind of related issues is seen in GDPR related research where researchers notice manual checking is much more complex because of time consuming and demands significant effort to identify and to verify relevant requirements [28]. The compliance requirements are expressed in legal terms which can be imprecise and confusing to interpret. So, it requires the expert knowledge as well[29]. Castellanos Ardila et al.[30] further stated that manual working is labor-intensive and difficult to scale as the requirements increase.

Automated Compliance Mapping

The automated compliance mapping comes to facilitate the human efforts by withdrawing all the requirements from the written documents and compare them with the help of AI models and technology used[31]. In general, the major goal is to achieve whether these two requirements are identical, equivalent, related, partially overlapping, or unmatched. This mapping is very effective in multi-standard mappings because automated mapping can help a lot to organizations to analyse requirements overlaps[19], reduce duplicated policies, and rectify limitations where further measures are needed.

2.1.4 Natural Language Processing (NLP) and LLM Techniques

Semantic Analysis

Semantic analysis is very crucial in automated compliance mapping because standards frequently articulate similar objectives using diverse terminology, structures, and viewpoints[32]. In term of engineering requirements, this is associated to common problem of mismatched vocabulary, where equivalent requirements may lack the same word despite of dealing with the the same underlying issue. This issue can be the major and relevant obstacle in our proposed thesis since ETSI EN 303 645 and ETSI EN 304 223 may not use the same or identical word while reporting the similar security objectives, like device-focused or governance-oriented language or life-cycle-based language[33] [34]. Thus, researcher suggest Semantic analysis assist much more effectively in the process of detecting conceptually similar kind of requirements across multiple standards rather than simply matching word [32].

NLP Techniques

Natural Language Processing (NLP) gives us the essential tools needed to transform standards and extract analyzable data from raw text. In research, NLP has been used in multiple tasks, such as identifying domain concepts, exposing language issues, and establishing traceability links between requirements. This shows that NLP is an ideal fit for standards mapping, in which the system must detect meaningful connections between sections written in respective natural languages[35].

For my thesis, the most applicable NLP techniques are as follows: text normalization, requirement extraction, sentence representation, and tokenization. A practical pipeline typically begins with extracting the normative statement, after which it starts to clean and normalize the text, and at the end, it starts to convert the requirement into a numerical representation that can be evaluated[36]. These steps are crucial due to its semantic similarity models, which work on vector representation instead of raw paragraphs.

LLM Techniques

Another technique can be LLM-based method which is relevant and rely on transformer architecture. This architecture is designed to accumulate the contextual relationship in language. The main mechanism of transformer model is self-attention which is used for learning relationships across the sequences. In other hand, BERT can be fine-tuned as its bidirectional contextual representation feature which can be good for performing many NLP tasks[37]. This is helpful in compliance mapping, as the standards typically have lengthy, formal, and contextual sentences which cannot be easily compared to simple key word techniques[33].

In order to sentence-wise semantic matching, Sentence-BERT (SBERT) is especially relevant. The main purpose of creating SBERT was to create sentence embedding. The idea was to compared easily using the cosine similarity and retain much of the semantic power of BERT[38]. This feature make it ideal for our proposed standard mapping where two different standards clauses are examined against each others. simultaneously, a recent literature on LLMs regarding IOT security demonstrates that these models carry high potential but it came with some negative aspects, including high computational cost, inability to be deployed in resource-intensive systems and lack of scalability[39].

Gap analysis

Gap analysis plays crucial role in addressing and identifying requirements, controls or security objectives when two standards are compared. The praposed thesis also experienced gap analysis to evaluate whether requirements from ETSI EN 303 645 have equivalent, partially related, or missing parts with ETSI EN 304 223 and vice versa. Analysing the gaps between two standards is necessary as it addresses related but different domains. ETSI EN 303 645 based on baseline cybersecurity requirements for consumer IoT devices, while ETSI EN 304 223 concentrates on cybersecurity requirements for AI systems and models throughout their lifecycle period [8, 9].

Evaluating gaps is highly relevance to our research questions as we are investigating whether NLP, embedding, and LLM-based methods can support automated compliance map-

ping. It is not sufficient to identify only strong semantic matches but also must find out if requirements are partially aligned or not related at all. Further research on compliance mapping shows that standards often differ in terminology, structure, scope, and level of detail, which makes direct comparison difficult and increases the need for expert interpretation [19, 20, 27].

2.2 Related work

2.2.1 Automated Compliance Mapping in Cybersecurity

In the paper *Towards Automated Assessment of Organizational Cybersecurity Posture in Cloud*, Bar-Haim et al. has illustrated an AI-driven method for automated assessment of organizational cybersecurity posture in cloud environments. The study addresses a core challenge that is relevant to our thesis. The research is also mentioned Security and compliance requirements are usually written in natural language, scattered across documents and systems, and therefore difficult to compare manually at scale[40]. To reduce this burden, the authors proposed automatic mapping of organizational security requirements to a standard control framework so that coverage gaps could be identified more efficiently.

Methodologically, the study formulated compliance mapping as a supervised text-pair classification task. The authors mapped requirements to two target frameworks: a NIST-based control framework containing 280 controls in 22 families, and a fine-grained three-level Risk and Control Framework with 169 categories. For implementation, they used transformer-based models, particularly RoBERTa and SBERT, and compared both individual and combined model performance. They also applied hard negative sampling by pairing each correct mapping with multiple difficult incorrect mappings, which forced the models to distinguish between semantically similar but non-equivalent controls. This design choice is especially relevant to our presented thesis, where proposed standards may use related vocabulary while expressing different security intents.

The reported results show both the potential and the limitations of automated compliance mapping. The best combined model, RoBERTa + SBERT, achieved about 72% Precision@1 for control-family mapping and about 55% Precision@1 for mapping to 280 individual controls, while Recall@10 reached 78%. For the fine-grained taxonomy, performance decreased as the mapping task became more detailed, showing that granular compliance alignment remains difficult. The authors therefore concluded that the approach is useful as a human-in-the-loop semi-automated system rather than a fully autonomous solution. Authors has suggested expert validation is necessary for precise and trustworthy results in cybersecurity compliance tasks.

2.2.2 NLP and Semantic Techniques for Requirement Mapping

Sapkota et al. [41], Automating the semantic mapping between regulatory guidelines and organizational processes, presented a semantic framework, called RegCMantic, for automatically mapping regulatory guidelines to organizational processes. The authors argue that manual compliance management is costly, error-prone, and difficult to maintain when regu-

lations change, and they identify three main challenges for automation: the lack of a standard framework for mapping regulation and process ontologies, the ambiguity and complexity of regulatory text, and the presence of implicit information in process descriptions. In response, they proposed a holistic approach that integrates information extraction, semantic representation, and similarity-based mapping.

Methodologically, the RegCMantic framework consists of two main parts: extraction and mapping. In the extraction stage, regulatory documents in formats such as PDF, DOC, and HTML are converted into a uniform XML structure through document-structure analysis, after which regulatory entities such as subject, obligation, action, and auxiliary information are identified and represented in a regulatory ontology. In the mapping stage, a regulatory statement is compared with an organizational process using three similarity measures: topic similarity, core-entity similarity, and auxiliary-entity similarity. The implementation combines NLP and Semantic Web tools, including GATE for text processing, JAPE rules for information extraction, Jena API with the Pellet reasoner for ontology interaction and inference, and WordNet-based Lin similarity for semantic comparison.

The framework was validated through a pharmaceutical-domain case study using the Eudralex regulation and the OntoReg process ontology. The results showed that the extended version of the framework outperformed the baseline version in the extraction task, improving overall precision from 0.89 to 0.96, recall from 0.78 to 0.86, and F-measure from 0.83 to 0.91. The study also reported strong results for extracting core entities, including an F-measure of 1.00 for obligations and 0.97 for actions in the extended framework. For the mapping stage, the authors evaluated computed mappings against expert-created mappings using precision, recall, and F-measure, and selected a threshold of 0.85 as the optimal operating point. Although the reported results were described as promising, the paper also acknowledged limitations, especially in handling auxiliary entities and in generalizing beyond the specific regulation-to-process setting. In conclusion, the study demonstrates that NLP, ontology-based representation, and semantic similarity can support automated requirement mapping, while also showing that ambiguity, implicit meaning, and domain-specific interpretation remain major challenges.

2.2.3 LLM-Based Approaches for Compliance Analysis

Rodríguez et al. [42], Large language models: a new approach for privacy policy analysis at scale, presented one of the most relevant recent studies on LLM-based compliance analysis. Their work investigates how large language models can be used to analyze privacy policies at scale in order to identify and categorize disclosures related to data protection and privacy compliance.

Methodologically, the authors compared ChatGPT and Llama 2 with earlier symbolic and machine-learning methods for privacy policy analysis. Their approach followed a Design Science Research process and focused on prompt engineering, model selection, and parameter optimization. In particular, they tested few-shot prompting and reported that a two-shot prompt design produced the best results. The evaluation was conducted on established datasets in privacy policy research, including MAPP and OPP-115, allowing comparison against prior approaches under realistic conditions [42].

The reported results show that LLMs can be highly effective for compliance-oriented text

analysis. The best ChatGPT configuration achieved an F1 score above 93%, outperforming earlier techniques reported in the literature. The study also found that ChatGPT generalized better than Llama 2 across datasets and offered practical advantages such as lower upfront development effort, reduced dependence on manually annotated corpora, and easier deployment. At the same time, the paper remains limited to privacy policy analysis. For this reason, it is highly relevant as evidence that LLMs can support compliance analysis.

3 | Research Methodology

3.1 Research Design

The research project will focus on experimental research methodology to evaluate the effectiveness of existing Natural Language Processing (NLP) and Large Language Model (LLM) techniques in identifying semantic similarity between regulatory security requirements on ETSI standard between ETSI EN 303 645 (IoT) and ETSI EN 304 223 (AI). In this project, we will be focusing on semantic similarity. This methodology is suitable for this study because it focuses on the objective to experimentally compare different NLP and LLM models to determine how accurately they can identify similar security requirements between the ETSI EN 303 645 (IoT) and ETSI EN 304 223 (AI) standard by aligning the overlapping controls across both security requirements standards and support automated compliance.

In this research, Unlike the design approach, this study will not develop or create a new algorithm or architecture, but instead it will be focusing on evaluation how well existing state of the art language models perform on regulatory text. While performing the methodology, we will be based on NLP-based and LLM semantic mapping capable of identifying relationships between compliance security requirements across standards to predict and compare the evaluation between the models. Compliance professionals often face challenges when aligning requirements from different standards. Manual mapping is time-consuming and prone to less consistencies. Therefore, the proposed research aims to focus on experimental research approach for compliance mapping. The methodology is designed to address the research questions as follows:

RQ1: Evaluate the capability of NLP and AI models to identify semantic relationships between security requirements.

RQ2: Compare the performance of rule-based, embedding-based, and LLM-based approaches.

RQ3: Assess how automated mappings compare with expert-generated mappings.

The method section will guide the reader on how the degree work was carried out. It describes the method step by step and usually in chronological order. The proposed methodology consists of a multi-stage NLP/LLM pipeline designed to transform unstructured regulatory text into structured semantic representations that can be compared automatically.

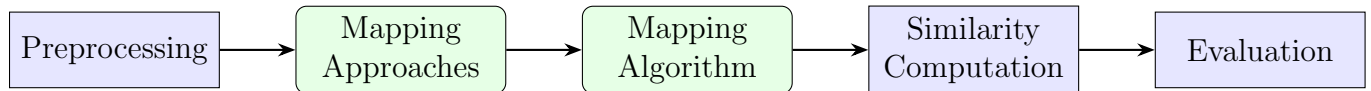


Figure 3.1: Machine Learning Data Pipeline

The research process consists of the following iterative stages:

- Dataset Preparation
- Text Pre-processing
- Automated Mapping Approaches
- Implementation of Mapping Algorithm
- Similarity computation
- Experimental evaluation of mapping performance
- Comparison of Results

The overall workflow of the research methodology is illustrated conceptually as a pipeline consisting of data acquisition, pre-processing, feature extraction, model training, similarity computation, and evaluation. The methodology behind this study had an experimental approach, and any implementation and evaluation of real-world treatment is left as possibilities for future work.

3.2 Data Gathering Methods

Selection of Security Standards

This project focuses on two cybersecurity standards published by ETSI that address security requirements in IoT (ETSI EN 303 645) and AI systems (ETSI EN 304 223)

ETSI EN 303 645: This standard defines baseline cybersecurity provisions for consumer IoT devices and establishes fundamental security principles that manufacturers should implement to protect devices and user data. The standard includes requirements related to authentication mechanisms, software updates, secure storage, vulnerability disclosure policies, and protection of sensitive data.

ETSI EN 304 223: This standard focuses on security assurance for AI-based systems, addressing aspects such as robustness, resilience, explainability, and risk management. The standard provides guidelines to ensure that AI systems operate securely and reliably under various operational conditions.

Requirement Extraction

Security standards contain descriptive and explanatory text in addition to normative requirements. Therefore, the first methodological step involves identifying and extracting only the statements that define compliance obligations.

Identification of Normative Requirements

Normative requirements typically contain modal verbs indicating obligation or recommendation. The following keywords were used to identify relevant clauses: SHALL, MUST, SHOULD, REQUIRED

Example requirement statement: "The device SHALL implement a secure mechanism for software updates."

Each extracted requirement is treated as a separate unit of analysis. The sentence segmentation will be performed using NLP libraries. Storage of extracted requirements in a structured dataset. Each requirement is assigned a unique identifier to facilitate traceability. Dataset structure: Standard ID, Standards Requirement, Processed Text

3.2.1 Text Pre-processing

Text processioning ensures consistency in linguistic representation and improves the performance of semantic similarity models.

Normalization

All extracted requirements are converted to lowercase to ensure uniformity and avoid duplication of semantically identical terms due to capitalization differences.

Example: "security update SHALL Protect Data" becomes "security update shall protect data"

Removal of Punctuation

Punctuation marks such as commas, brackets, and semicolons are removed because they do not contribute significantly to semantic meaning in most NLP tasks.

Stop Word Removal

Stop words are common words that carry minimal semantic value, such as "the", "is", "at", and "which". Removing these words reduces noise in the dataset and improves similarity calculations.

Example: "The device shall use the security update" becomes "device use security update"

Lemmatization

Lemmatization converts words into their root forms to ensure consistent representation of similar terms. It improves similarity matching between semantically related requirements.

Examples:

devices → device protecting → protect encrypted → encrypt

Tokenization

Tokenization divides sentences into individual words or tokens. it enables the model to process text efficiently. Example:

”device protect data” becomes a list: device, protect, data

Domain-Specific Terminology Handling

Cybersecurity standards include technical terms such as authentication, encryption, integrity, vulnerability, and confidentiality. These terms are preserved during pre-processing because they provide essential contextual meaning for compliance analysis.

3.3 Automated Mapping Approaches

In this automated mapping approaches we are evaluating the three categories in this study: rule-based NLP methods, semantic embedding models, and large language models. This diverse selection enables a comprehensive comparison of traditional, modern, and state-of-the-art techniques.

Rule Based Methods

Rule-based methods serve as baseline approaches. These include TF-IDF cosine similarity, keyword overlap, and Jaccard similarity. Although computationally efficient, such methods rely heavily on lexical similarity and often struggle when semantically equivalent requirements use different terminology.

Semantic Embedding Models

Semantic embedding models, including BERT and Sentence-BERT, generate dense vector representations that capture contextual meaning. These models are particularly effective for regulatory text because they can recognize semantic equivalence even when wording differs significantly.

LLM Models

Large Language Models, such as GPT or Claude, are evaluated using prompt-based classification. Instead of relying solely on similarity scores, LLMs directly classify the relationship between two requirements into predefined categories. This allows them to capture nuanced semantic relationships that may be difficult for embedding models to identify.

3.4 Implementation of Mapping Algorithm

In this section, we perform the mapping algorithm that compares each IoT requirement with every AI requirement. The metrics are used to compare the mapping algorithm with manual expert mapping in terms of Accuracy, overage, efficiency and interpretability and find

out the different automated approaches (Rule-based NLP, Semantic (BERT-based, sentence embedding), LLM(GPT, Claude)) perform for compliance mapping tasks and will help to measure and evaluate which methods achieve the best balance. The section will answer the RQ2 and This section follows the same structure as those steps, with the exception of explaining the metrics and tools used for mapping. we validate the performance of the automated approaches by comparing its results to an annotated validation dataset that had been annotated by a policy expert. The result from this provide a complete answer for RQ2. Following procedure are followed for the mapping algorithms:

First we will select requirement from EN 303 645 and compare with all requirements from EN 304 223 and to check the relationship and similarity we compute cosine similarity score between both standards and we test which models has given the best score as AI requirements according to similarity score. we will then select matches exceeding predefined similarity threshold. The similarity threshold values between 0.70 and 0.85 are evaluated experimentally. Finally the output of the algorithm is a ranked list of potential mappings between IoT and AI requirements.

3.4.1 Classification of Mapping Relationships

For this project while mapping between the models score to find the similarities which have the similar security requirements in both standards. we classify the identified relationships that are categorized into four types:

Equivalent: Equivalent requirements refers the requirements express similar security objectives using different terminology.

Partially: Partially related requirements indicates overlapping concepts.

Supporting control: Supporting control relationships refers security controls represent indirect relationships where one requirement contributes to the effectiveness of another.

No relationship: No relationship refers that there is no relationship between the requirements.

3.4.2 Experimental evaluation of mapping performance

For the experimental evaluation of the mapping performances of the models we have selected the following metrics and tools used to evaluate and validate the various models that are defined in this section. In addition to checking the accuracy of how a model performed on a testing set, precision, recall, and F1-score metrics were used along with the K-fold cross-validation method.

In this Confusion Matrix, here TP = True Positives, FN = False Negatives, FP = False Positives, TN = True Negatives.

Precision

Precision measures the proportion of predicted mappings that are correct.

Regular Expression: The formula for **precision** is:

Table 3.1: Tabular of Confusion Metrix

Features	Predicted Positives	Predicted Negatives
Positive Value	TP	FN
Negative Value	FP	TN

$$\text{Precision} = \frac{TP}{TP + FP} \quad (3.1)$$

Where, Precision = Correct mappings / Total predicted mappings

Recall

Recall measures the proportion of actual mappings that the system successfully identifies.

Regular Expression: The formula for **precision** is:

$$\text{Recall} = \frac{TP}{TP + FN} \quad (3.2)$$

Where, Recall = Correct mappings / Total true mappings

F1 Score

F1-score balances precision and recall to provide a single performance metric.

Regular Expression: The **F1-score** is the harmonic mean of Precision and Recall:

$$F_1 = 2 \cdot \frac{\text{Precision} \cdot \text{Recall}}{\text{Precision} + \text{Recall}} \quad (3.3)$$

Where, A higher F1-score indicates better mapping accuracy.

K-fold cross-validation

K-fold cross-validation is a method for validating a model by partitioning the dataset into k subsets, training the model on k - 1 subsets, and testing the model on the remaining subset. This is repeated until all subsets have been used as the testing set.

Choosing the Value of K

The choice of K affects the trade-off between bias and variance: Small K (e.g., K =2 or K=5): Faster computation with increased variance in performance estimates.

Large K (e.g., K =10 or K =n, where n is the size of the dataset): Lower variance but higher computational cost.

K =n corresponds to Leave-One-Out Cross Validation (LOOCV). A standard choice is 10-Fold Cross Validation that is a good trade-off between bias and variance in most situations. The final result was calculated as a average of all results across the k subsets.

3.5 Similarity Computation

In this project to answer RQ1, a existing state of the machine learning framework are used and the decision was to be made based on the factors of data and manual at each data granularity level. The domain specific terminology levels are defined by the level of detail in the texts. To enable mathematical comparison of textual requirements, each requirement is transformed into a numerical representation called a vector. The data was prepared before being processed by machine learning models by first applying it through an NLP pipeline. Whilst there were many different algorithms and packages to utilized for each task in the pipeline. The NLP pipeline comprises of three tasks: text parsing, text normalization, and text vectorization. Meanwhile, the machine learning classifier consists of a single binary classifier. For a more detailed view of each task within the machine learning pipeline, observe Figure below:

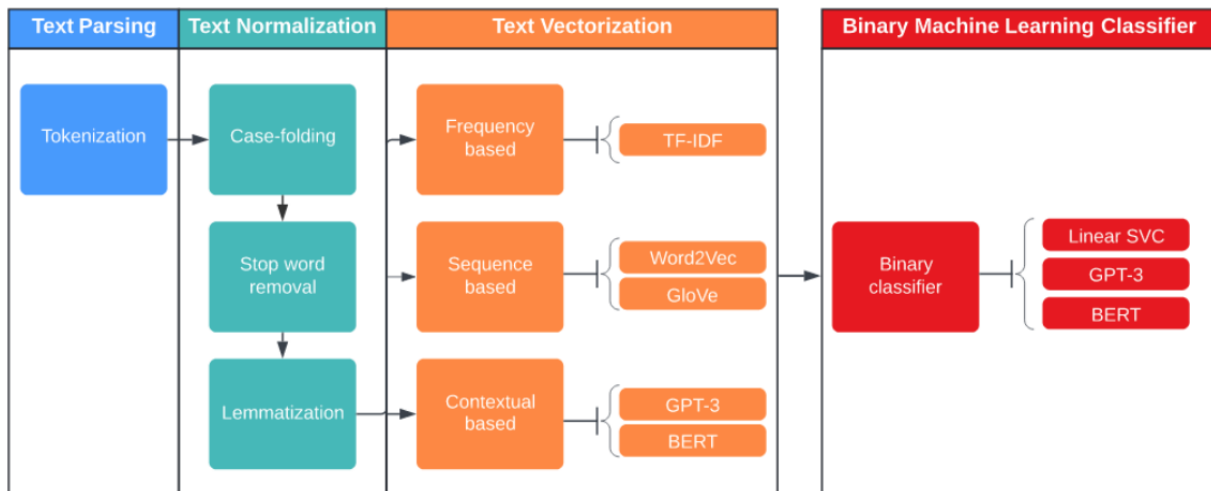


Figure 3.2: Detailed view of the machine learning pipeline including subtasks

In Figure 7, we can see the detail wireframe of the ML pipeline where text parsing is defined by tokenizing the text and acts as an input to the text normalization task, which has the three sub-tasks: case-folding, stop-word removal, and lemmatization. For case-folding, the python standard library string operations were used. For the stop-word removal and lemmatization, a pre-defined list of stop-words and a lemmatizer algorithm known as the WordNetLemmatizer, of which both came from the NLTK-library, were used. The following task, text vectorization, consisted of the three different types of word embedding models. The TF-IDF vectorizer from the scikit-learn library was selected to represent the frequency-based model. For the sequence-based models, Word2Vec and GloVe models from the Gensim library were selected. Finally, GPT-3 from OpenAI and BERT from the TensorFlow library were selected for the contextual-based models to capture contextual relationships between words within sentences. Sentence-BERT (SBERT) is selected as the primary embedding model because it produces high-quality sentence representations suitable for semantic similarity tasks. Once requirements are represented as vectors, similarity between requirements can be

computed mathematically. Cosine similarity measures the cosine of the angle between two vectors, indicating how similar two requirements are in semantic space.

The formula for **cosine similarity** is:

$$\text{similarity} = \cos(\theta) = \frac{\mathbf{A} \cdot \mathbf{B}}{\|\mathbf{A}\| \|\mathbf{B}\|} \quad (3.4)$$

Where:

- A represents the vector of a requirement from EN 303 645
- B represents the vector of a requirement from EN 304 223

The similarity will be calculated using the similarity scores range from 0 to 1. A score closer to 1 indicates stronger semantic similarity.

The main reasoning behind the selected combination of sub-tasks used for text normalization was to mimic the preprocessing of other pre-trained word embedding models and maximize the gain from their usage by aligning the tokenized words. The output from the NLP pipeline was then inserted as input into the binary machine learning classifier, where GPT-3 and BERT, on the other hand, did not need a stand-alone binary classifier as the models handled the classification internally.

3.6 Model comparison

The model comparison was performed by comparing different NLP techniques, semantic analysis techniques, and LLM based approaches to determine the most suitable NLP approach for automated compliance mapping between ETSI EN 303 645 and ETSI EN 304 223, multiple Natural Language Processing models are evaluated and compared based on their ability to capture semantic similarity between security requirements. Some of the NLP models capture only word frequency, while others capture deeper contextual meaning. Since, security requirements often use domain-specific terminology, selecting the appropriate model significantly impacts mapping accuracy. so this comparison focuses on how effectively each model identifies relationships between requirements expressed using different terminology but representing similar security objectives.

Table 3.2: Example Model Comparision Framework

Model	Precision	Recall	F1 Score
TF-TDF	0.60	0.55	0.52
Word2Vec	0.68	0.64	0.63
Glove	0.71	0.66	0.64
Bert	0.80	0.73	0.77
SBert	0.85	0.82	0.84

The table represents that with the average of all the performance, we can say that TF-TDF performance has a low semantic understanding, Word2Vec performance has a moderate likewise Glove shows the improve similarity and Bert shows the strong contextual

understanding between the models whereas SBert shows the best performance among the models.

4 | “Prototype”

If a prototype system has been developed, this needs to be described here. Replace “...” in the title with the name of your system or something descriptive of your work. Some hints for writing this chapter:

- Use figures!
- Figures should either be drawn by you, or carefully cited in the caption.
- Figures should always be referenced in the text, and explained in the text what they represent/contain.
- You should start with a structural overview of your prototype/system/algorithm/Framework.
- Show clearly what parts you have created, and which parts that were already existing when you started. Remember that assembling existing components can also be a contribution.
- Avoid programming code and strangely-sounding variable/function names.
- You are free to call a module something else than what it is called in the source code.
- Always have the reader in mind when writing. Be pedagogic.

5 | Results and discussion

The Results and discussion section presents a detailed and objective description of the results. This can be done by showing tables, figures which are numbered and given explanatory figure/table texts. Figure numbering is below the figure while the tables get their numbering above. If tables or figures are too big or too many, the most interesting are added in this section and the rest must be placed in the appendix, see Appendix. In graphs don't forget to state units and to use the figure area optimal. Avoid strange/hard reading colours and symbols; it must be easy for the reader to understand the graphs. This section must also conclude the results and findings (or if too extensive in a new section for result discussion). The purpose is to discuss and analyse the meaning of the results related to the theoretical framework, related jobs and methodology. Questions to be asked when you write this section: what do the readings say, how likely are they, can they be generalized, how significant are the results, outliers, etc. In this part, personal reflections are allowed.

Conclusion

The final aim of the study is to make conclusions from what is analysed, implement-ed, tested or measured. Discuss and answer all the aims and questions formulated in the introduction. The conclusions drawn should refer to the initial aims, objectives, literature and problems. The validity of the conclusions should also be discussed and evaluated.

5.0.1 Future Work and Research

It is common to conclude with a section on future work, either as part of the conclusion section or as a new chapter. It is sometimes important to recognize how the project can move forward in solving future problems.

5.0.2 Critical Discussion

Personal reflections and personal experiences during the work.

5.0.3 Generalization of the result

Discuss how general the result is and if they can be useful in other areas. How unique is this study?

Bibliography

- [1] P. van Oorschot, *Computer Security and the Internet: Tools and Jewels*. Information Security and Cryptography, Springer International Publishing, 2020.
- [2] M. Shahin, M. A. Babar, and L. Zhu, “Continuous integration, delivery and deployment: a systematic review on approaches, tools, challenges and practices,” *IEEE Access*, vol. 5, pp. 3909–3943, 2017.
- [3] M. M. Aslam, A. Tufail, H. Gul, *et al.*, “Artificial intelligence for secure and sustainable industrial control systems – a survey of challenges and solutions,” *Artificial Intelligence Review*, vol. 58, p. 349, 2025.
- [4] B. Alotaibi, “A survey on industrial internet of things security: Requirements, attacks, ai-based solutions, and edge computing opportunities,” *Sensors*, vol. 23, no. 17, p. 7470, 2023.
- [5] O. A. Cejas, M. I. Azeem, S. Abualhaija, and L. C. Briand, “Nlp-based automated compliance checking of data processing agreements against gdpr,” *IEEE Transactions on Software Engineering*, vol. 49, no. 9, pp. 4282–4303, 2023.
- [6] H. Meziane and N. Ouerdi, “A survey on performance evaluation of artificial intelligence algorithms for improving iot security systems,” *Scientific Reports*, vol. 13, p. 21255, 2023.
- [7] S. Deep, X. Zheng, A. Jolfaei, D. Yu, P. Ostovari, and A. K. Bashir, “A survey of security and privacy issues in the internet of things from the layered context,” *arXiv preprint arXiv:1903.00846*, 2020.
- [8] “Cyber Security for Consumer Internet of Things: Baseline Requirements,” June 2020. CYBER; baseline security requirements for consumer IoT.
- [9] “Securing Artificial Intelligence (SAI); Baseline Cyber Security,” Dec. 2025. ETSI Technical Committee Securing Artificial Intelligence (SAI).
- [10] O. Kosenkov, P. Elahidoost, T. Gorschek, J. Fischbach, D. Mendez, M. Unterkalmsteiner, D. Fucci, and R. Mohanani, “Systematic mapping study on requirements engineering for regulatory compliance of software systems,” *Information and Software Technology*, vol. 178, p. 107622, 2025.

- [11] H. Sebestyen, D. E. Popescu, and R. D. Zmaranda, “A literature review on security in the internet of things: Identifying and analysing critical categories,” *Computers*, vol. 14, no. 2, p. 61, 2025. Open access under CC BY 4.0 license.
- [12] S. Themann, “Challenges and strategies used in implementing ai governance: A systematic literature review,” master’s thesis, Department of Computer and Systems Sciences, Stockholm University, Stockholm, Sweden, 2025. Degree project 30 HE credits; Supervisor: Lazar Rusu; Reviewer: Paul Johannes.
- [13] Q. Chen, L. Tan, J. Tang, and X. Qu, “Ai-enabled iot security: A survey on advances, challenges, and cross-domain collaborative frameworks,” in *Proceedings of the 2025 8th International Conference on Computer Information Science and Artificial Intelligence (CISAI '25)*, pp. 1615–1621, ACM, 2025.
- [14] D. Canavese, A. Ferreira, L. Kamm, and A. Q. Rodriguez, “Uncovering challenges of cybersecurity cross-regulation in eu legislation,” *Information and Software Technology*, vol. 193, p. 108033, 2026.
- [15] O. Amaral, M. I. Azeem, S. Abualhaija, and L. C. Briand, “Nlp-based automated compliance checking of data processing agreements against gdpr,” *arXiv preprint arXiv:2209.09722*, 2022.
- [16] F. Ariai, J. Mackenzie, and G. Demartini, “Natural language processing for the legal domain: A survey of tasks, datasets, models, and challenges,” *ACM Computing Surveys*, vol. 58, no. 6, pp. 163:1–163:37, 2025.
- [17] R. Kakarla, “Predictive compliance automation using nlp and policy-as-code,” *ISAR Journal of Science and Technology*, vol. 3, no. 3, pp. 87–93, 2025. Open access under CC BY-NC license.
- [18] H. Lundblad and P. Faramarzi, “An nlp approach to assess information security policies: Application of gpt-3 within a policy domain,” master’s thesis, Chalmers University of Technology and University of Gothenburg, Gothenburg, Sweden, 2022. Supervisor: Mirosław Staron; Advisor: Daniel Dalevi; Examiner: Lucas Gren.
- [19] F. Djebbar and K. Nordström, “A comparative analysis of industrial cybersecurity standards,” *IEEE Access*, vol. PP, pp. 1–1, 01 2023.
- [20] A. Mussmann, M. Brunner, and R. Breu, *Mapping the State of Security Standards Mappings*, pp. 1309–1324. 03 2020.
- [21] S. Sicari, A. Rizzardi, L. Grieco, and A. Coen-Porisini, “Security, privacy and trust in internet of things: The road ahead,” *Computer Networks*, vol. 76, pp. 146–164, 2015.
- [22] G. Vardakis, G. Hatzivasilis, E. Koutsaki, and N. Papadakis, “Review of smart-home security using the internet of things,” *Electronics*, vol. 13, no. 16, 2024.

- [23] D. Mocrii, Y. Chen, and P. Musilek, “Iot-based smart homes: A review of system architecture, software, communications, privacy and security,” *Internet of Things*, vol. 1-2, pp. 81–98, 2018.
- [24] H. Chen and M. A. Babar, “Security for machine learning-based software systems: A survey of threats, practices, and challenges,” *ACM Comput. Surv.*, vol. 56, Feb. 2024.
- [25] X. He, G. Xu, X. Han, Q. Wang, L. Zhao, C. Shen, C. Lin, Z. Zhao, Q. Li, L. Yang, *et al.*, “Artificial intelligence security and privacy: a survey,” *Science China Information Sciences*, vol. 68, no. 8, p. 181101, 2025.
- [26] D. Olifer, N. Goranin, A. Cenys, A. Kaceniauskas, and J. Janulevicius, “Defining the minimum security baseline in a multiple security standards environment by graph theory techniques,” *Applied Sciences*, vol. 9, no. 4, 2019.
- [27] A. Tanveer, C. Sharma, R. Sinha, and M. M. Kuo, “Tracing security requirements in industrial control systems using graph databases,” *Software and Systems Modeling*, vol. 22, no. 3, pp. 851–870, 2023.
- [28] O. A. Cejas, M. I. Azeem, S. Abualhaija, and L. C. Briand, “Nlp-based automated compliance checking of data processing agreements against gdpr,” *IEEE Transactions on Software Engineering*, vol. 49, no. 9, pp. 4282–4303, 2023.
- [29] C. Negri-Ribalta, M. Lombard-Platet, and C. Salinesi, “Understanding the gdpr from a requirements engineering perspective—a systematic mapping study on regulatory data protection requirements,” *Requirements Engineering*, vol. 29, no. 4, pp. 523–549, 2024.
- [30] J. P. Castellanos Ardila, B. Gallina, and F. Ul Muram, “Compliance checking of software processes: A systematic literature review,” *Journal of Software: Evolution and Process*, vol. 34, no. 5, p. e2440, 2022.
- [31] A. Sleimi, N. Sannier, M. Sabetzadeh, L. Briand, M. Ceci, and J. Dann, “An automated framework for the extraction of semantic legal metadata from legal texts,” *Empirical Software Engineering*, vol. 26, May 2021. Publisher Copyright: © 2021, The Author(s), under exclusive licence to Springer Science+Business Media, LLC part of Springer Nature.
- [32] A. Mahmoud and N. Niu, “On the role of semantics in automated requirements tracing,” *Requirements Engineering*, vol. 20, no. 3, pp. 281–300, 2015.
- [33] D. Rajpathak, P. M. Peranandam, and S. Ramesh, “Automatic development of requirement linking matrix based on semantic similarity for robust software development,” *Journal of Systems and Software*, vol. 186, p. 111211, 2022.
- [34] K. Sapkota, A. Aldea, M. Younas, D. A. Duce, and R. Banares-Alcantara, “Automating the semantic mapping between regulatory guidelines and organizational processes,” *Service Oriented Computing and Applications*, vol. 10, no. 4, pp. 365–389, 2016.

- [35] L. Zhao, W. Alhoshan, A. Ferrari, K. J. Letsholo, M. A. Ajagbe, E.-V. Chioasca, and R. T. Batista-Navarro, “Natural language processing for requirements engineering: A systematic mapping study,” *ACM Computing Surveys (CSUR)*, vol. 54, no. 3, pp. 1–41, 2021.
- [36] R. Sonbol, G. Rebdawi, and N. Ghneim, “The use of nlp-based text representation techniques to support requirement engineering tasks: A systematic mapping review,” *IEEE Access*, vol. 10, pp. 62811–62830, 2022.
- [37] J. Devlin, M.-W. Chang, K. Lee, and K. Toutanova, “BERT: Pre-training of deep bidirectional transformers for language understanding,” in *Proceedings of the 2019 Conference of the North American Chapter of the Association for Computational Linguistics: Human Language Technologies, Volume 1 (Long and Short Papers)* (J. Burstein, C. Doran, and T. Solorio, eds.), (Minneapolis, Minnesota), pp. 4171–4186, Association for Computational Linguistics, June 2019.
- [38] N. Reimers and I. Gurevych, “Sentence-BERT: Sentence embeddings using Siamese BERT-networks,” in *Proceedings of the 2019 Conference on Empirical Methods in Natural Language Processing and the 9th International Joint Conference on Natural Language Processing (EMNLP-IJCNLP)* (K. Inui, J. Jiang, V. Ng, and X. Wan, eds.), (Hong Kong, China), pp. 3982–3992, Association for Computational Linguistics, Nov. 2019.
- [39] S. Jamshidi, N. Shahabi, A. Nikanjam, K. W. Nafi, F. Khomh, and C. Fung, “The role of large language models in iot security: A systematic review of advances, challenges, and opportunities,” *Internet of Things*, vol. 34, p. 101735, 2025.
- [40] R. Bar-Haim, L. Eden, Y. Kantor, V. Agarwal, M. Devereux, N. Gupta, A. Kumar, M. Orbach, and M. Zan, “Towards automated assessment of organizational cybersecurity posture in cloud,” in *Proceedings of the 6th Joint International Conference on Data Science & Management of Data (10th ACM IKDD CODS and 28th COMAD)*, CODS-COMAD '23, (New York, NY, USA), p. 167–175, Association for Computing Machinery, 2023.
- [41] K. Sapkota, A. Aldea, M. Younas, D. A. Duce, and R. Banares-Alcantara, “Automating the semantic mapping between regulatory guidelines and organizational processes,” *Service Oriented Computing and Applications*, vol. 10, no. 4, pp. 365–389, 2016.
- [42] D. Rodriguez, I. Yang, J. M. Del Alamo, and N. Sadeh, “Large language models: a new approach for privacy policy analysis at scale,” *Computing*, vol. 106, no. 12, pp. 3879–3903, 2024.

Glossary and Symbols

ISO The International Organization for Standardization is an international standard development organization composed of representatives from the national standards organizations of member countries.

NIST NIST is the National Institute of Standards and Technology at the U.S. Department of Commerce.

CPS Cyber-physical systems (CPS) and the Internet of Things (IoT) are both complex platforms that share a common goal of increasing technological reliability, expanding advancement opportunities and exposing areas of untapped potential